

# От фишинга до захвата домена: Детальный разбор атаки на белорусскую компанию

 [redsec.by/article/ot-fishinga-do-zahvata-domena-detalnyj-razbor-ataki-na-beloruskuyu-kompaniyu](https://redsec.by/article/ot-fishinga-do-zahvata-domena-detalnyj-razbor-ataki-na-beloruskuyu-kompaniyu)

Red Teams | 22 октября 2025



В современном цифровом ландшафте кибератаки перестали быть гипотетической угрозой и превратились в ежедневную реальность для бизнеса любого масштаба. Особенно уязвимыми остаются корпоративные инфраструктуры, построенные на базе Windows Active Directory (AD) — центральной нервной системы большинства организаций. Данная статья представляет собой детальный, пошаговый разбор типовой, но от этого не менее разрушительной атаки на белорусскую компанию,

проведенный с точки зрения специалиста по наступательной безопасности (Red Team). Мы пройдем весь путь злоумышленников: от отправки хитроумного фишингового письма до полного захвата контроллера домена, и, что более важно, вскроем критические ошибки администраторов, которые сделали эту атаку возможной.

## Анатомия реальной киберугрозы

---

Корпоративные сети на базе Windows Active Directory остаются главной целью для злоумышленников в Беларуси. Согласно данным Kaspersky, в третьем квартале 2023 года количество фишинговых атак, нацеленных на кражу учетных записей Telegram у белорусских пользователей, выросло в 21 раз по сравнению с первым кварталом того же года. При этом до 79% фишинговых сообщений маскируются под финансовую документацию, что делает их особенно эффективными против сотрудников финансовых и бухгалтерских отделов.

Современная кибератака — это не хаотичный взлом, а хорошо спланированный и методичный процесс. Он включает в себя разведку, эксплуатацию человеческих и технических уязвимостей, закрепление в системе и последующее перемещение по сети для достижения конечной цели. В нашем сценарии эта цель — получение полного контроля над доменом, что эквивалентно получению "ключей от королевства".

Мы рассмотрим этот процесс в деталях, чтобы не просто описать угрозу, но и предоставить системным администраторам и специалистам по безопасности четкое понимание того, как мыслят атакующие и какие меры необходимо предпринять для защиты своей инфраструктуры.

### Этап 1: Начальный доступ (Initial Access) — Фишинговое письмо

---

**Временная метка: День 0, 09:00**

#### Техника атаки

Все начинается с целенаправленной фишинговой атаки (spear-phishing). В отличие от массовых рассылок, spear-phishing направлен на конкретных сотрудников. Злоумышленники заранее проводят разведку, собирая информацию из открытых источников (сайт компании, социальные сети), чтобы сделать свое сообщение максимально правдоподобным. Письмо маскируется под срочный бухгалтерский документ от известного и реального подрядчика.

#### Содержимое письма:

- **Тема:** "Срочно: Счет №2025-1045 к оплате до 22.10.2025"

- **Вложение:** Счет\_октябрь\_2025.docx (в действительности — документ с вредоносным макросом)
- **Отправитель:** Подделанный, но визуально неотличимый email-адрес реального контрагента.

## Эксплуатация

Сотрудник бухгалтерии, находясь в рутине ежедневных задач, открывает документ. Microsoft Office отображает предупреждение о безопасности, но текст письма настойчиво просит "включить содержимое" для корректного отображения счета. Сотрудник нажимает кнопку, и в этот момент запускается скрытый макрос. Этот макрос, в свою очередь, активирует PowerShell (стандартный инструмент Windows), который незаметно для пользователя загружает и выполняет первичный вредоносный код (payload) с удаленного сервера.

В качестве payload выступает **Cobalt Strike Beacon** — мощный и гибкий инструмент для удаленного управления. Изначально созданный для легитимных тестов на проникновение, он, к сожалению, стал популярен и среди киберпреступников благодаря своей стабильности и широким возможностям по маскировке.

## Инструменты:

- Документ Word с поддержкой макросов
- PowerShell для загрузки и выполнения кода
- Cobalt Strike Beacon (с настроенным HTTP/HTTPS listener для связи)

## Ошибки администраторов:

- **Критическая ошибка 1: Отсутствие ограничений на выполнение макросов.** Для большинства пользователей, не работающих с программированием в Office, макросы должны быть отключены централизованно через групповые политики (GPO). Исследования показывают, что более 90% атак с использованием программ-вымогателей начинаются именно с фишинга.
- **Критическая ошибка 2: Недостаточная сегментация сети.** Рабочая станция бухгалтера имеет прямой доступ к внутренним серверам и контроллеру домена. Сеть должна быть разделена на сегменты (VLAN), чтобы изолировать рабочие места пользователей от критической инфраструктуры.

## Этап 2: Установление плацдарма и разведка (Execution & Discovery)

---

Временная метка: День 0, 09:15 - 11:30

## Закрепление в системе

После успешного запуска Beacon устанавливает постоянное, но скрытое подключение к командному серверу (Command & Control, C2) атакующих. Чтобы обмануть системы обнаружения вторжений, Beacon связывается с C2 не постоянно, а с определенными интервалами и случайной задержкой (jitter), маскируя свой трафик под обычную веб-активность.

Атакующие проверяют, под какой учетной записью они получили доступ:

```
beacon> getuid
Current User: COMPANY\i.ivanova
beacon> shell whoami /groups
Domain Users
BUILTIN\Users
Они видят, что находятся в системе под правами обычного доменного пользователя. Этог
Разведка Active Directory
Следующий шаг – составить карту домена, чтобы найти пути для повышения привилегий. [
Атакующие запускают сборщик данных SharpHound прямо в памяти скомпрометированного кс
beacon> execute-assembly SharpHound.exe -c All -d company.local
beacon> download *_BloodHound.zip
```

SharpHound отправляет легитимные LDAP-запросы к контроллеру домена, собирая информацию о пользователях, группах, компьютерах, сессиях и правах доступа. Этот процесс сложно отличить от нормальной активности администратора.

Анализ собранных данных в интерфейсе BloodHound выявляет критическую цепочку уязвимостей:

```
i.ivanova (Domain Users)
→ имеет право GenericWrite на группу "Helpdesk"
→ члены группы "Helpdesk" имеют права локального администратора на сервере "SRV-
→ на сервере "SRV-FILE01" активна сессия администратора домена "admin_petrov"
```

Атакующие нашли свой "джекпот".

### Ошибки администраторов:

- **Критическая ошибка 3: Избыточные права в Active Directory.** Обычный пользователь не должен иметь прав на изменение членства в группах. Право GenericWrite — это классическая ошибка конфигурации, позволяющая атакующему добавить себя в привилегированную группу.
- **Критическая ошибка 4: Использование учетной записи администратора домена для повседневных задач.** Администратор admin\_petrov вошел на обычный файловый сервер под своей самой привилегированной учетной записью. Это грубейшее нарушение принципа минимальных привилегий и разделения учетных записей.

## Этап 3: Повышение привилегий (Privilege Escalation)

---

Временная метка: День 0, 12:00 - 14:30

### Манипуляция объектами Active Directory

Используя найденное право GenericWrite, атакующие добавляют скомпрометированного пользователя i.ivanova в группу Helpdesk с помощью одной простой команды:

```
beacon> powershell Add-ADGroupMember -Identity "Helpdesk" -Members "i.ivanova"
```

Теперь у них есть права локального администратора на файловом сервере SRV-FILE01.

### Латеральное перемещение (Lateral Movement)

Следующая задача — переместиться с рабочей станции бухгалтера на целевой сервер. Для этого используется классический инструмент PsExec, встроенный в функциональность Cobalt Strike:

```
beacon> jump psexec64 SRV-FILE01 smb-beacon  
[+] established link to child beacon: 10.10.50.15
```

Эта команда удаленно создает на сервере SRV-FILE01 новую службу Windows, запускает ч Ошибки администраторов:

Критическая ошибка 5: Слабая сегментация административных учетных записей. Используются  
Критическая ошибка 6: Отсутствие мониторинга. Системы мониторинга (SIEM) и EDR должны  
Этап 4: Кража Учетных Данных (Credential Access)

Временная метка: День 0, 14:30 - 15:00

Дамп учетных данных из памяти LSASS

Находясь на сервере SRV-FILE01, атакующие знают, что там активна сессия администратора

```
beacon> logonpasswords
```

Dumping credentials from LSASS...

Username : admin\_petrov

Domain : COMPANY

NTLM : a87f3a337d73085c45f9416be5787d86

SHA1 : d5e8f...

Mimikatz успешно извлекает NTLM-хеш пароля администратора домена. Это не сам пароль в открытом виде, но в мире Windows-атак этого более чем достаточно.

### Ошибки администраторов:

- **Критическая ошибка 7: Хранение учетных данных администратора домена в памяти рядового сервера.** Это прямое следствие ошибки №4.

- **Критическая ошибка 8: Не настроены механизмы защиты LSASS.**  
Современные версии Windows Server поддерживают технологии, такие как Credential Guard и LSA Protection (RunAsPPL), которые используют виртуализацию для изоляции процесса LSASS и предотвращения прямого доступа к его памяти.
- **Критическая ошибка 9: Повторное использование паролей.** Если бы пароль администратора домена был уникальным и никогда не использовался на других системах, риск его компрометации был бы ниже.

## Этап 5: Латеральное перемещение к контроллеру домена

---

Временная метка: День 0, 15:15 - 16:00

### Атака Pass-the-Hash (PtH)

Получив NTLM-хеш, атакующим не нужно подбирать пароль. Они могут использовать его напрямую для аутентификации на других машинах в домене с помощью техники **Pass-the-Hash**. Это возможно из-за особенностей старого протокола аутентификации NTLM, который все еще включен по умолчанию во многих сетях.

```
beacon> pth COMPANY/admin_petrov a87f3a337d73085c45f9416be5787d86
beacon> jump psexec64 DC01.company.local smb-beacon
established link to child beacon: 10.10.10.10
```

С помощью украденного хеша атакующие успешно аутентифицируются на контроллере домена (DC01) и запускают на нем еще один Beacon. Игра окончена.

### Альтернативный путь: Pass-the-Ticket (PtT)

Если бы NTLM был отключен, атакующие могли бы использовать другую технику — **Pass-the-Ticket**. Вместо хеша они бы украли из памяти LSASS активный билет Kerberos (TGT) и использовали его для доступа к ресурсам.

### Ошибки администраторов:

- **Критическая ошибка 10: Протокол NTLM не отключен.** В современных сетях следует принудительно использовать более безопасный протокол Kerberos и отключать NTLM через групповые политики.
- **Критическая ошибка 11: Отсутствие решений для управления привилегированным доступом (PAM/PIM).** Такие системы предоставляют администраторам права "точно в срок" (Just-in-Time) и только для конкретных задач, что исключает наличие постоянных привилегированных сессий на серверах.

## Этап 6: Захват контроллера домена и закрепление

---

Временная метка: День 0, 16:00 - 17:00

## Атака DCSync

Получив доступ к контроллеру домена с правами администратора, атакующие могут выполнить самую разрушительную атаку — **DCSync**. Эта техника позволяет злоумышленнику, притворившись другим контроллером домена, запросить данные для репликации. В ответ целевой DC отправляет хеши паролей всех пользователей домена.

```
beacon> dcsync company.local COMPANY\krbtgt
```

```
[J Dumping KRBTGT hash:
```

```
[J NTLM: 508d7c8f8c8e9d2b1c4e5a6f7d8e9c0aAES256:  
b8c9d0e1f2a3b4c5d6e7f8a9b0c1d2e3...
```

Атакующие целенаправленно запрашивают хеш пароля учетной записи `krbtgt`. Это специализированное "Золотое билет" (Golden Ticket)

Получив хеш `krbtgt`, атакующие могут создавать поддельные билеты Kerberos, известные как Golden Ticket. Например, можно использовать следующий URL для поиска информации о Golden Ticket: <https://www.google.com/url?sa=E&q=https%3A%2F%2Fvertexaisearch.cloud.google.com%2Fbeacon%2Fmimikatz%2Fkerberos%3A%3Agolden%2Fuser%3Aadmin%2Fdomain%3Acompany.local%2Fsid%3AS-1-5-21-...>

С этим билетом атакующие могут вернуться в сеть в любое время, даже если все пароли администраторов будут сменены. Единственный способ обезвредить Golden Ticket — дважды сменить пароль от учетной записи krbtgt.

### Ошибки администраторов:

- **Критическая ошибка 12: Отсутствие мониторинга репликации.** Запросы на репликацию (DCSync) от систем, не являющихся контроллерами домена, являются стопроцентным индикатором компрометации и должны немедленно вызывать тревогу (Событие Windows ID 4662).
- **Критическая ошибка 13: Пароль krbtgt никогда не менялся.** Пароль этой учетной записи должен меняться регулярно (например, каждые 90-180 дней) по строгому регламенту.
- **Критическая ошибка 14: Недостаточное логирование.** Отсутствие расширенного аудита событий безопасности AD не позволяет ретроспективно расследовать инцидент и понять, как именно действовали атакующие.

## Временная шкала атаки: 8 часов до катастрофы

| Время       | Этап                 | Инструменты                      | Критические действия                                  |
|-------------|----------------------|----------------------------------|-------------------------------------------------------|
| 09:00       | Initial Access       | Phishing Email, Malicious Macro  | Компрометация рабочей станции i.ivanova               |
| 09:15       | Execution            | PowerShell, Cobalt Strike Beacon | Установление C2 соединения                            |
| 09:30-11:30 | Discovery            | BloodHound, SharpHound           | Картирование AD, обнаружение пути эскалации           |
| 12:00-14:30 | Privilege Escalation | PowerShell AD Cmdlets, PsExec    | Добавление в группу Helpdesk, доступ к SRV-FILE01     |
| 14:30-15:00 | Credential Access    | Mimikatz                         | Дамп учетных данных Domain Admin из LSASS             |
| 15:15-16:00 | Lateral Movement     | Pass-the-Hash, Cobalt Strike     | Перемещение на контроллер домена DC01                 |
| 16:00-17:00 | Domain Compromise    | DCSync (Mimikatz), Golden Ticket | Извлечение всех хешей паролей, создание Golden Ticket |

**Итог: от фишингового письма до полного захвата домена прошло всего 8 часов.** Это стандартный рабочий день. Согласно исследованиям, среднее время от первоначальной компрометации до захвата домена может составлять от нескольких часов до пары дней, что подчеркивает критическую важность скорости обнаружения и реагирования.

## Рекомендации по защите: Как не стать следующей жертвой

Эффективная защита требует многоуровневого подхода (Defense in Depth). Ниже приведены ключевые рекомендации, основанные на разобранных ошибках.

### Превентивные меры:

- **Архитектура Tier Model:** Разделите вашу инфраструктуру на уровни (Tiers). **Tier 0** — это контроллеры домена и учетные записи администраторов домена. **Tier 1** — серверы. **Tier 2** — рабочие станции. Запретите администраторам Tier 0 входить на системы Tier 1 и Tier 2. Это предотвратит кражу их учетных данных с менее защищенных систем.



- **Рабочие станции с привилегированным доступом (PAW):** Администраторы должны выполнять свои задачи с выделенных, закаленных и изолированных рабочих станций, на которых нет доступа к интернету и почте.
- **LAPS (Local Administrator Password Solution):** Внедрите бесплатное решение от Microsoft LAPS для управления паролями локальных администраторов. Оно создает уникальные, сложные и регулярно меняющиеся пароли для каждой машины, что блокирует латеральное перемещение.
- **Защита учетных данных:** Включите **Credential Guard** для изоляции процесса LSASS. Добавляйте всех привилегированных пользователей в группу **Protected Users**, которая принудительно включает более строгие политики Kerberos и отключает кеширование учетных данных.
- **Блокировка макросов и отключение NTLM:** Централизованно через GPO заблокируйте макросы в документах Office, полученных из интернета, и отключите устаревшую аутентификацию NTLM, сделав ставку на Kerberos.

### Меры обнаружения:

---

- **Microsoft Defender for Identity (MDI) / Advanced Threat Analytics (ATA):** Эти решения специально разработаны для мониторинга трафика Active Directory и используют поведенческий анализ для обнаружения атак, таких как DCSync, Golden Ticket, Pass-the-Hash и др.
- **Настройка SIEM и EDR:** Настройте правила корреляции в вашей SIEM-системе для отслеживания ключевых событий (ID 4662, 7045, 4624, 4688). Разверните EDR-решения на всех конечных точках для мониторинга подозрительной активности процессов, особенно доступа к LSASS.
- **"Канарейки" (Honeytokens):** Создайте фейковые привилегированные учетные записи, которые никто не должен использовать. Любая активность по ним — это верный признак атаки.

### Процедуры реагирования:

---

При подозрении на компрометацию домена и атаку Golden Ticket необходимо:

- Немедленно отключить скомпрометированные учетные записи.
- **Дважды** сменить пароль учетной записи krbtgt с интервалом репликации.
- Проверить и отозвать все активные сессии.
- Принудительно сменить пароли для всех привилегированных и, в идеале, всех пользовательских учетных записей.
- Провести полное криминалистическое расследование для выявления точки входа и всех действий злоумышленников.

Рассмотренный сценарий — это не выдержка из голливудского фильма, а суровая реальность для многих компаний, в том числе в Беларуси. Атака стала успешной не из-за одной единственной уязвимости "нулевого дня", а вследствие **цепочки**

**накопившихся ошибок** в конфигурации, отсутствии базовых мер гигиены безопасности и недостаточного мониторинга.

Ключевые выводы для любой организации:

- **Человеческий фактор — все еще слабое звено:** Обучение сотрудников распознаванию фишинга критически важно.
- **Легитимные инструменты в руках врага:** Атакующие активно используют встроенные средства Windows (PowerShell, PsExec, LDAP), что усложняет их обнаружение.
- **Скорость имеет значение:** Современные атаки развиваются стремительно. У вас есть часы, а не дни, чтобы отреагировать.
- **Проактивная защита — единственный выход:** Не ждите инцидента. Регулярно проводите аудиты безопасности, тесты на проникновение (Red Team) и внедряйте многоуровневую защиту.

Только комплексный подход, сочетающий в себе современные технологии, грамотные архитектурные решения и постоянное повышение осведомленности сотрудников, может эффективно противостоять современным киберугрозам.